

CONFIDENCIAL

REPORTE DE PRUEBAS DE VULNERABILIDADES APLICACIÓN TESTFIRE

04 de mayo de 2026 • CONFIDENCIAL

Descripción

Este documento fue preparado por SANTANA CYBERSECURITY para ACME . El mismo puede contener información confidencial o propiedad de SANTANA CYBERSECURITY. Cualquier distribución o copia del contenido de este documento, completa o en parte, requiere del permiso escrito de SANTANA CYBERSECURITY . SANTANA CYBERSECURITY otorga a ACME permiso de reproducción completa o en parte de este documento para los propósitos que requiera la ejecución de este proyecto.

Preparado por

SANTANA CYBERSECURITY

ACERCA DE SANTANA CYBERSECURITY

SANTANA CYBERSECURITY es una firma de consultoría en Tecnología de Información. Cuenta con más de 1 año de experiencia con la visión de ser líder en innovación tecnológica. Nos hemos posicionado y destacado en áreas de seguridad informática; análisis de datos; diseño de sistemas; investigación, desarrollo e innovación (I+D+i) y consultoría ejecutiva.

Innovamos constantemente para hacer más competitivos a nuestros clientes. Con el slogan “Somos su brazo de innovación en tecnología de información” hemos desarrollado plataformas para fortalecer la gestión de seguridad de nuestros clientes, el Servicio de Vigilancia Administrada (SOC), facilitar mantener al día sus análisis de riesgo (AR), analizar datos comerciales o públicos, depurar base de datos usando tecnología Web semántica y hemos acompañado a equipos estratégicos en lograr transformación digital.

CONTENIDO

- CONTENIDO 2
- Declaración de Confidencialidad 4
- Descargo de Responsabilidad 4
- Información de Contacto..... 4
- 1. RESUMEN EJECUTIVO 5
 - 1.1 Alcance 5
 - 1.2 ESTADO DE SEGURIDAD DE LOS ACTIVOS 5
 - 1.3 CLASIFICACIONES DE RIESGO DE LAS VULNERABILIDADES..... 7
 - 1.4 RECOMENDACIONES 9
- 2. PRUEBAS DE PENTEST 10
 - 2.1 DESCRIPCIÓN DEL SERVICIO 10
 - 2.2 DESCUBRIMIENTO Y RECONOCIMIENTO 10
 - 2.3 VALIDACIÓN Y EXPLOTACIÓN 10
- 3. HALLAZGOS 11

Vulnerabilidades

Vulnerabilidad 1: Cross-Site Scripting (XSS) reflejado en parámetro de búsqueda.....	11
--	----

Declaración de Confidencialidad

Este documento fue preparado por SANTANA CYBERSECURITY. El mismo contiene información confidencial o de propiedad de SANTANA CYBERSECURITY. Cualquier distribución o copia del contenido de este documento, completa o en parte, requiere del permiso escrito de SANTANA CYBERSECURITY. Asimismo, SANTANA CYBERSECURITY otorga a ACME permiso de reproducción completa o en parte de este documento para los propósitos que requiera la ejecución de este proyecto.

Descargo de Responsabilidad

Una evaluación de diagnóstico de ciberseguridad se considera una instantánea en el tiempo. Las conclusiones y recomendaciones reflejan la información recopilada durante la evaluación y no los cambios o modificaciones realizados fuera de ese periodo.

SANTANA CYBERSECURITY recomienda realizar evaluaciones similares anualmente por parte de evaluadores internos o de terceros para garantizar el éxito continuo de los controles.

Información de Contacto

Nombre	Cargo	Correo Electrónico
CARLOS HENRY SANTANA PALOMINO	Penetration Tester	carlos.santana.p@uni.pe

1. RESUMEN EJECUTIVO

ACME ha decidido mejorar el modelo de Gestión de Seguridad de la información con el que cuenta actualmente, para ello, ACME solicitó el apoyo de SANTANA CYBERSECURITY (en adelante “SANTANA CYBERSECURITY”) para realizar una revisión de vulnerabilidades manual (penetration testing) a activos internos dentro de su red interna.

1.1 Alcance

El alcance de la prueba para este compromiso incluyó que ACME contratara a SANTANA CYBERSECURITY para llevar a cabo una Prueba de Penetración de caja gris sobre la app web ACME_WebAPP. Las pruebas y preparación del informe se realizaron del 02 de mayo de 2026 al 03 de mayo de 2026.

El objetivo de este servicio era realizar pruebas específicas y garantizar una amplia cobertura de los tipos de vulnerabilidad más comunes. Todas las pruebas realizadas se basan en el Manual de Metodología de Pruebas de Seguridad de Código Abierto (OSSTMM), el Proyecto Abierto de Seguridad de Aplicaciones Web (OWASP) y marcos de pruebas personalizados. Las pruebas se realizaron utilizando herramientas y marcos de pruebas de penetración estándar del sector, como Burp Suite.

Los módulos evaluados se especifican en la siguiente tabla:

ID	Tipo	Nombre	URL	Estado
1	Aplicación web	ALTORO MUTUAL	https://testfire.net	activo

1.2 ESTADO DE SEGURIDAD DE LOS ACTIVOS

Mantener una postura de seguridad saludable requiere una revisión constante y el refinamiento de los procesos de seguridad existentes. La realización de un pentest de SANTANA CYBERSECURITY permite al equipo de seguridad interno de ACME no sólo descubrir vulnerabilidades específicas, sino también comprender mejor el panorama actual de las amenazas a la seguridad.

Para resumir, durante la evaluación se encontraron una (01) vulnerabilidades en la aplicación, clasificada en Alta severidad, que afecta la seguridad de los datos y la integridad del sistema. Esta vulnerabilidad expone a la aplicación a riesgos como el secuestro de sesiones bancarias, la suplantación de identidad de los usuarios (Account Takeover) y la ejecución no autorizada de scripts en el navegador, lo que podría derivar en fraudes financieros.

La severidad de estos hallazgos se distribuye como muestra el siguiente gráfico:

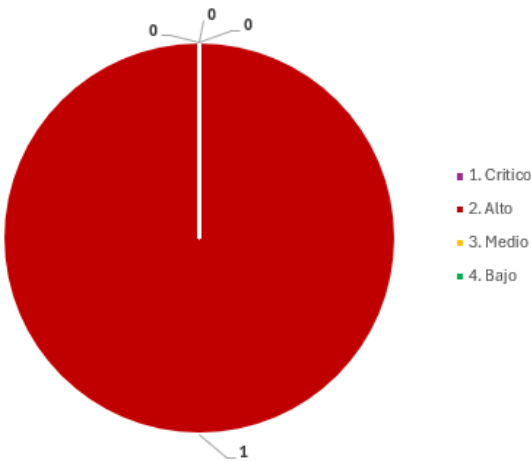


Ilustración 1: Distribución de hallazgos distintos por severidad

Para generar la imagen anterior, cada hallazgo corresponde a una debilidad en la aplicación que podría derivar en una vulnerabilidad de seguridad si no se gestiona adecuadamente. Esta representación permite visualizar de manera simplificada el estado de la aplicación desde la perspectiva de riesgo y facilidad de remediación.

En la siguiente tabla se listan los hallazgos identificados, junto con la cantidad de ocurrencias y el nivel de severidad asignado en función del impacto potencial y la probabilidad de explotación. Los hallazgos han sido ordenados de mayor a menor severidad, y luego según un criterio técnico que prioriza la factibilidad de corrección por parte del equipo de desarrollo.

La siguiente tabla muestra los sitios de alcance y el desglose de los hallazgos por gravedad.

Descripción	Critical	High	Medium	Low	Info	Σ
Activos en el alcance	0	1	0	0	0	1

En mayor detalle, se da cuenta de las vulnerabilidades:

#	Vulnerabilidad	Severidad
1	Cross-Site Scripting (XSS) Reflejado en parámetro de búsqueda	High

A continuación, se presenta un resumen de cada una:

Durante la evaluación del portal bancario, se identificó una brecha de seguridad en la barra de búsqueda que permite la ejecución de código malicioso. Si un ciberdelincuente engaña a un cliente legítimo para que haga clic en un enlace manipulado, el atacante puede robar silenciosamente su sesión activa sin necesidad de conocer su contraseña. Para Altoro Mutual, esto representa un riesgo crítico de toma de control de cuentas y posibles fraudes financieros. Esta situación podría derivar en penalizaciones regulatorias y un daño profundo a la reputación de la institución. Se recomienda priorizar la asignación de recursos para aplicar las correcciones detalladas en este informe.

1.3 CLASIFICACIONES DE RIESGO DE LAS VULNERABILIDADES

Para clasificar las vulnerabilidades de acuerdo con un estándar, SANTANA CYBERSECURITY utiliza el estándar de la industria de la Common Weakness Enumeration (CWE), el cual sirve como un lenguaje común, para medir para la seguridad de software, y también nos da una línea de base para la identificación de debilidades, la mitigación y los esfuerzos de prevención.

Para calificar la gravedad de las vulnerabilidades, SANTANA CYBERSECURITY utiliza el Common Vulnerability Scoring System (CVSS), el cual es un estándar del sector, para calcular la gravedad de cada vulnerabilidad de seguridad identificada. El CVSS proporciona una forma de capturar las principales características de una vulnerabilidad y producir una puntuación numérica que refleje su gravedad, así como una representación textual de dicha puntuación. Para ayudar a priorizar las vulnerabilidades y ayudar a los procesos de gestión de vulnerabilidades, SANTANA

CYBERSECURITY traduce la calificación numérica del CVSS a una representación cualitativa (como baja, media, alta y crítica):

CRITICAL	CVSS rating 9.0-10
HIGH	CVSS rating 7.0-8.9
MEDIUM	CVSS rating 4.0-6.9
LOW	CVSS rating 0.1-3.9
INFO	CVSS rating 0

Esta escala de cinco puntos refleja tanto la probabilidad de explotación como el impacto empresarial de la misma. A continuación, se presenta una breve descripción de cada nivel de gravedad.

Cada uno de los hallazgos en el presente informe es ponderado con un nivel de severidad determinado por las consecuencias asociadas que se describen en la siguiente tabla:

Nivel de severidad	Descripción
Crítico	Se puede obtener fácilmente el control del activo comprometiendo completamente el estado de la seguridad. La consumación de un ataque podría causar interrupciones de servicio, alteración, o hurto, de contenido u otras consecuencias intolerables para la empresa o clientes. Tipo de acción: Los riesgos identificados con este nivel requieren acción inmediata.
Alto	Se logra la obtención de privilegios, información de configuraciones, contenido de archivos, navegación en directorios restringidos, usos no autorizados y negaciones de servicios. Ataques complejos de realizar para explotar la vulnerabilidad también son considerados. Tipo de acción: Se requiere de acciones que mitiguen los riesgos en el corto plazo.
Medio	Incluyen fallas en comportamiento normal del sistema, negaciones de servicios complejas de realizar, aportan información u acceso muy limitado, requieren acceso a la red local de la víctima (física y lógica) y manipulación específica (Ej: ingeniería social). Tipo de acción: Los riesgos identificados requieren medidas de corto a mediano plazo.
Bajo	Indica información que puede ser recolectada (puertos, servicios, versiones de software) como paso inicial a otros hallazgos para planificación de pruebas de vulnerabilidad. Tipo de acción: Representan riesgos que pueden ser sobrellevados o tolerados en el largo plazo, aunque no sea lo recomendable.

Tabla 1: Clasificación de severidad en hallazgos

Puede encontrar más información sobre CWE en el sitio web de MITRE: <https://cwe.mitre.org/>. Asimismo, puede encontrar más información sobre el CVSS en el sitio web del Foro de Equipos de Seguridad y Respuesta a Incidentes (FIRST): <https://www.first.org/cvss>.

1.4 RECOMENDACIONES

Las siguientes recomendaciones proporcionan orientación para mejorar la postura de seguridad de la aplicación:

1. Para mejorar la seguridad de la aplicación y reducir el riesgo asociado a la vulnerabilidad identificada, se propone una estrategia de remediación en tres etapas:

En el corto plazo, se recomienda implementar reglas de bloqueo en el Firewall de Aplicaciones Web (WAF) corporativo para detener de inmediato los intentos de ataque dirigidos a la funcionalidad de búsqueda. Esto permitirá contener el riesgo mientras se desarrolla una solución definitiva.

A mediano plazo, es fundamental asignar recursos al equipo de desarrollo para incorporar controles adecuados de validación de entradas y codificación de salida en el código. De esta manera, se asegura que toda la información ingresada por los usuarios sea tratada únicamente como datos y no como instrucciones ejecutables por el navegador.

Finalmente, en el largo plazo, se sugiere fortalecer la arquitectura de seguridad mediante la implementación de políticas como Content Security Policy (CSP) y reforzar la protección de las sesiones de los usuarios. Estas medidas ayudarán a prevenir vulnerabilidades similares en el futuro y a mantener el cumplimiento de las normativas financieras aplicables.

2. PRUEBAS DE PENTEST

2.1 DESCRIPCIÓN DEL SERVICIO

Las pruebas de penetración se realizaron desde Internet, se proporcionaron usuarios de la aplicación asociado a varios roles; asimismo, todas las pruebas se ejecutaron en varias fases relacionadas.

- En la fase de planificación, se establecieron el objetivo de las pruebas y accesos asociados.
- La fase de descubrimiento incluyó el escaneo automatizado que junto con pruebas manuales para explorar y comprender el objetivo de las pruebas.
- La fase de ataque comprendía los esfuerzos para explotar cualquier vulnerabilidad detectada, y sintetizar el conocimiento obtenido sobre el entorno, su tecnología, sus usuarios y su función en una escalada de privilegios.
- La fase final registraba todos los hallazgos de forma que sirviera de apoyo a la evaluación de riesgos y a la reparación por parte del ACME .

La evaluación se ejecutó bajo una metodología de Caja Gris, simulando un atacante con conocimientos parciales y acceso a nivel de usuario. Las pruebas se rigieron por fases estructuradas: Descubrimiento, Validación y Explotación. Las herramientas principales empleadas incluyeron Burp Suite para la interceptación de tráfico, en estricto cumplimiento con el marco de pruebas OWASP WSTG

2.2 DESCUBRIMIENTO Y RECONOCIMIENTO

Como primer paso de este compromiso, si bien se tenía un alcance se realizó el descubrimiento y reconocimiento del entorno. Esto incluye la realización de escaneos de la red o de la aplicación; la revisión de la arquitectura del sistema, de la red o de la aplicación; o el recorrido por un escenario típico de uso del entorno. Los resultados del descubrimiento y el reconocimiento determinan las posibles áreas vulnerables que pueden ser explotadas.

2.3 VALIDACIÓN Y EXPLOTACIÓN

Se utilizó los resultados de los esfuerzos de reconocimiento como punto de partida para los intentos manuales de comprometer la Confidencialidad, Integridad y Disponibilidad (CIA) del entorno y los datos contenidos en él.

3. HALLAZGOS

Vulnerabilidad 1: Cross-Site Scripting (XSS) reflejado en parámetro de búsqueda

Criticidad	HIGH
Puntuación Vector	8.2. CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:L/A:N
CWE	CWE-79: Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting').
DESCRIPCION: Se identificó que la aplicación no sanitiza los datos ingresados en la funcionalidad de búsqueda. Al estar un usuario autenticado, un atacante puede inyectar código JavaScript que se ejecuta en el navegador de la víctima, permitiendo el acceso a variables de entorno críticas como las cookies de sesión. IMPACTO: La vulnerabilidad permite la exfiltración del token AltoroAccounts. Con esta información, un atacante puede realizar un secuestro de sesión (Session Hijacking), accediendo a la cuenta bancaria del usuario sin necesidad de credenciales, lo que facilita fraudes financieros y robo de datos personales.	
Evidencia (Prueba de Concepto)	
Para demostrar la vulnerabilidad y su impacto en usuarios autenticados, se siguieron estos pasos: 1. Autenticación: Se inició sesión en el portal (http://testfire.net/) con credenciales de usuario legítimo para generar cookies de sesión activas. 2. Inyección: En el campo de búsqueda, se ingresó el script: <code><script>alert(document.cookie)</script></code>. 3. Interceptación: Se utilizó Burp Suite para capturar la petición GET dirigida a search.jsp a través del parámetro query. 4. Ejecución: Al procesar la solicitud con el botón Forward, el servidor reflejó el script en el navegador, disparando una ventana emergente que muestra el contenido íntegro de la cookie AltoroAccounts.	
Sistemas Afectados	
GET http://testfire.net/search.jsp?query=	
Recomendaciones	
• Configurar reglas en el WAF corporativo para bloquear peticiones que contengan vectores de inyección como etiquetas <code><script></code> hacia la ruta de búsqueda en search.jsp. • Implementar la codificación de salida (Output Encoding) en el backend para que los caracteres especiales ingresados en el parámetro query se conviertan en texto plano seguro antes de mostrarse en pantalla. • Implementar cabeceras de seguridad como Content Security Policy (CSP) para restringir la ejecución de scripts no autorizados y evitar la carga de contenido malicioso. • Asegurar la cookie de sesión AltoroAccounts configurando los atributos HttpOnly y Secure para evitar que la información sea extraída mediante scripts del lado del cliente.	
Referencias	
OWASP Top 10 (2025) - Injection: https://owasp.org/Top10/2025/A05_2025-Injection/	
CWE-79: Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')	

ANEXO

Inicio de sesión con usuario legítimo.

The screenshot shows a web browser window with the address bar displaying "testfire.net/bank/main.jsp". The website is "Altoro Mutual". The navigation bar includes links for "Sign Off", "Contact Us", "Feedback", and a search bar. A "DEMO SITE ONLY" banner is visible. The main content area is titled "Hello John Smith" and includes a welcome message, a "View Account Details" section with a dropdown menu showing "800002 Savings" and a "GO" button, and a "Congratulations!" message stating that the user has been pre-approved for an Altoro Gold Visa with a credit limit of \$100,000. A sidebar on the left lists links for "View Account Summary", "View Recent Transactions", "Transfer Funds", "Search News Articles", and "Customize Site Language". The footer contains links for "Privacy Policy", "Security Statement", "Server Status Check", "REST API", and copyright information for Altoro Mutual, Inc. and HCL Technologies, Ltd.

Altoro Mutual

Sign Off | Contact Us | Feedback | Search <script>alert(document.cookie) Go

MY ACCOUNT PERSONAL SMALL BUSINESS INSIDE ALTORO MUTUAL

I WANT TO ...

- View Account Summary
- View Recent Transactions
- Transfer Funds
- Search News Articles
- Customize Site Language

Hello John Smith

Welcome to Altoro Mutual Online.

View Account Details: 800002 Savings GO

Congratulations!

You have been pre-approved for an Altoro Gold Visa with a credit limit of \$100,000!

Click [Here](#) to apply.

Privacy Policy | Security Statement | Server Status Check | REST API | © 2026 Altoro Mutual, Inc. This web application is open source! Get your copy from GitHub and take advantage of advanced features

The AltoroJ website is published by HCL Technologies, Ltd. for the sole purpose of demonstrating the effectiveness of HCL products in detecting web application vulnerabilities and website defects. This site is not a real banking site. Similarities, if any, to third party products and/or websites are purely coincidental. This site is provided "as is" without warranty of any kind, either express or implied. HCL does not assume any risk in relation to your use of this website. For more information, please go to <https://www.hcl-software.com/aposcan/>.

Copyright © 2008, 2017, IBM Corporation, All rights reserved. Copyright © 2017, 2026, HCL Technologies, Ltd., All rights reserved.

Burp Suite interceptando el script.

Intercept on Forward Drop Request to http://testfire.net:80 [65.61.137.117] Open browser ?

Time	Type	Direction	Method	URL	Status code	Length
21:12:08 3...	HTTP	→ Request	GET	http://testfire.net/search.jsp?query=%3Cscript%3Ealert%28document.cookie%29%3C%2Fscript%3E		

Request

Pretty Raw Hex GraphQL

```
1 GET /search.jsp?query=%3Cscript%3Ealert%28document.cookie%29%3C%2Fscript%3E HTTP/1.1
2 Host: testfire.net
3 Accept-Language: es-ES,es;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/146.0.0.0 Safari/537.36
6 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application
  /signed-exchange;v=b3;q=0.7
7 Referer: http://testfire.net/bank/main.jsp
8 Accept-Encoding: gzip, deflate, br
9 Cookie: JSESSIONID=[REDACTED]; AltoroAccounts=[REDACTED]
10 Connection: keep-alive
11
12
```

Inspector

- Request attributes: 2
- Request query parameters: 1
- Request body parameters: 0
- Request cookies: 2
- Request headers: 9

Search 0 highlights

Contenido íntegro de la cookie AltoroAccounts.

Altoro Mutual

No es seguro testfire.net/search.jsp?query=<script>alert%28document.cookie%29<%2Fscript>

testfire.net dice

AltoroAccounts=[REDACTED]

Aceptar